

Lab: Blind SQL injection with time delays

1. Mục đích của bài lab

Tìm hiểu và khai thác lỗ hổng Blind SQL Injection dạng Time-Based. Thông qua việc chèn câu lệnh SQL vào cookie TrackingId, người thực hiện có thể làm cơ sở dữ liệu trì hoãn phản hồi trong một khoảng thời gian xác định, từ đó xác nhận sự tồn tại của lỗ hổng SQL Injection ngay cả khi ứng dụng không hiển thị kết quả truy vấn hoặc thông báo lỗi.

2. Trả lời câu hỏi

Câu 1: What distinguishes Time-Based SQL Injection from other SQL injection techniques?

-Time-Based SQL Injection khác với các kỹ thuật SQL Injection khác ở chỗ nó không dựa vào dữ liệu trả về hay thông báo lỗi từ ứng dụng, mà dựa vào sự thay đổi thời gian phản hồi của máy chủ. Kẻ tấn công chèn các hàm tạo độ trễ như `pg_sleep()` hoặc `SLEEP()` vào câu lệnh SQL và quan sát thời gian phản hồi để xác định điều kiện đúng hay sai. Phương pháp này đặc biệt hữu ích trong các trường hợp Blind SQL Injection, khi ứng dụng không hiển thị kết quả truy vấn hoặc lỗi, vì kẻ tấn công vẫn có thể suy luận và trích xuất thông tin từ cơ sở dữ liệu thông qua các độ trễ thời gian.

Câu 2: Describe the process of executing a Time-Based SQL Injection attack on a vulnerable web application. What are the key steps in crafting a SQL query that causes a deliberate delay in the database response.

-Quá trình thực hiện một cuộc tấn công Time-Based SQL Injection bao gồm việc xác định điểm nhập liệu dễ bị tổn thương, chèn một truy vấn SQL có chứa hàm tạo độ trễ của cơ sở dữ liệu và quan sát thời gian phản hồi của ứng dụng. Nếu phản hồi chậm hơn đáng kể so với bình thường, điều đó cho thấy câu lệnh SQL đã được thực thi thành công.

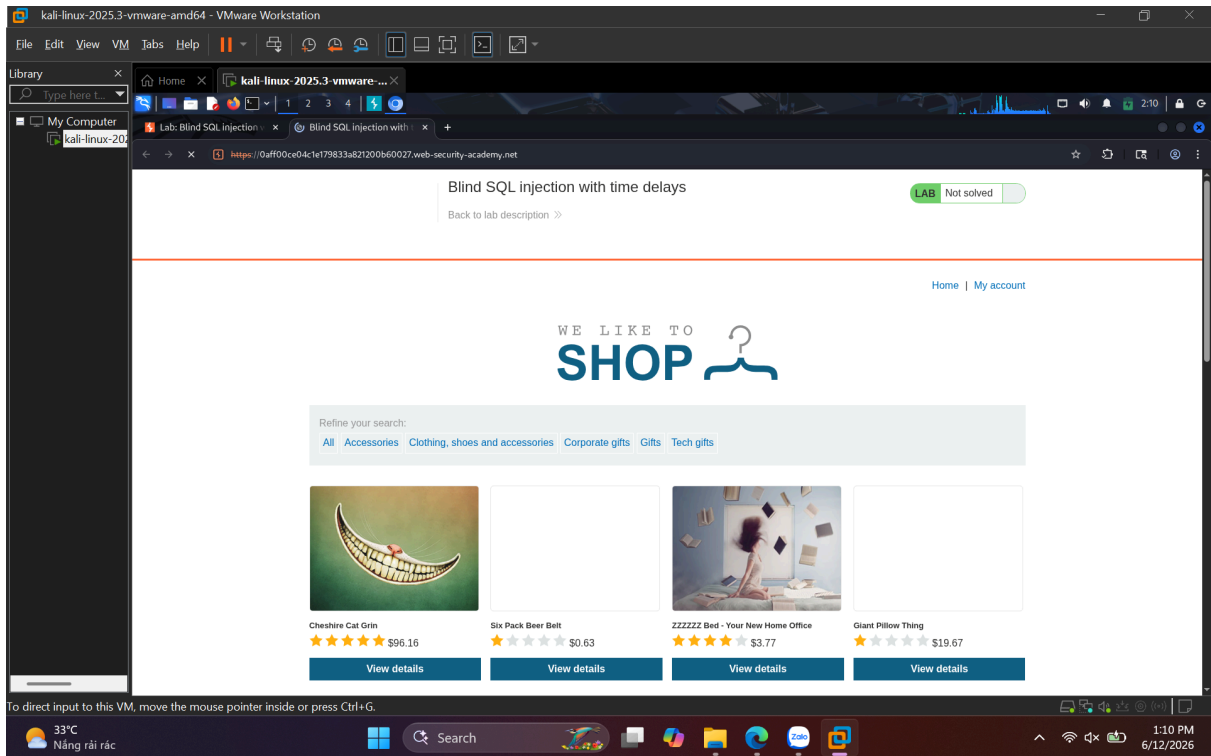
Các bước chính gồm:

1. Xác định tham số hoặc đầu vào có khả năng bị SQL Injection.
2. Chèn một payload SQL chứa hàm tạo độ trễ (ví dụ các hàm ngủ/chờ của hệ quản trị cơ sở dữ liệu).
3. Gửi yêu cầu và đo thời gian phản hồi của máy chủ.
4. So sánh thời gian phản hồi để xác định liệu điều kiện trong truy vấn có được thỏa mãn hay không.
5. Lặp lại quá trình với các điều kiện khác nhau để suy luận thông tin từ cơ sở dữ liệu.

Kỹ thuật này đặc biệt hiệu quả trong các trường hợp Blind SQL Injection, khi ứng dụng không hiển thị dữ liệu truy vấn hoặc thông báo lỗi, vì kẻ tấn công vẫn có thể thu thập thông tin dựa trên sự khác biệt về thời gian phản hồi của hệ thống.

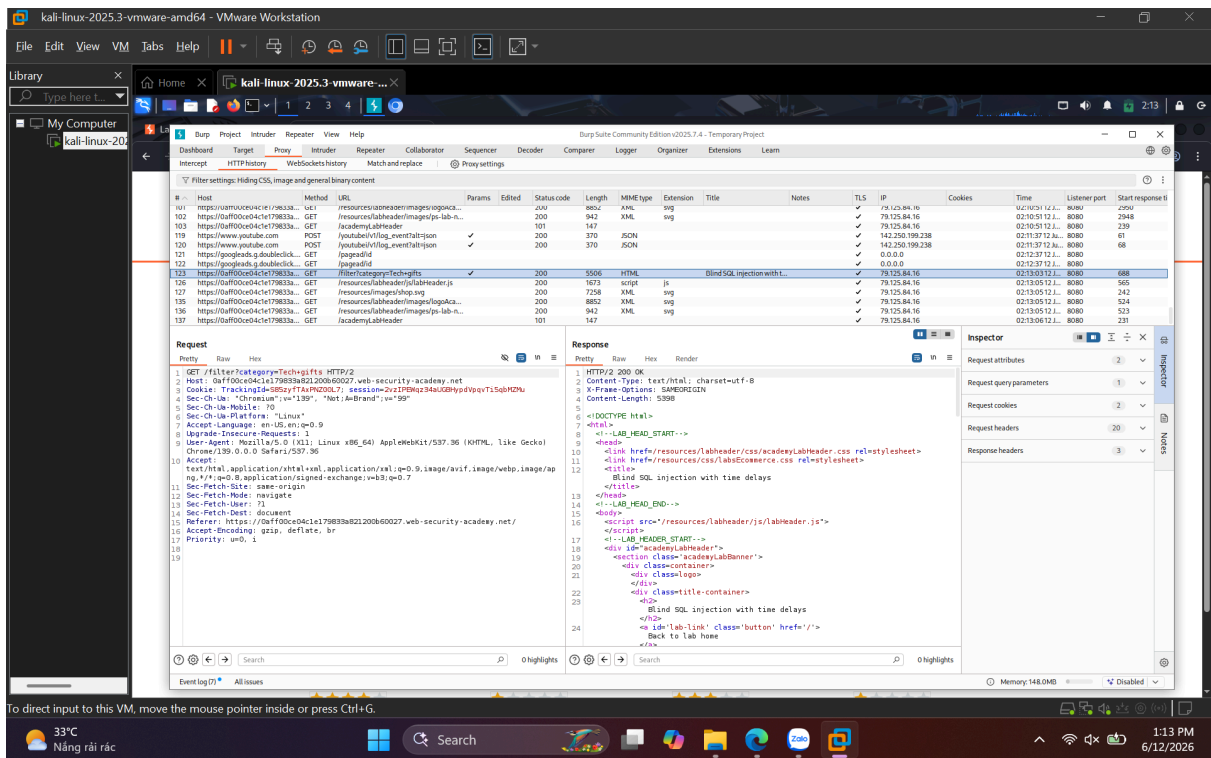
3. Chi tiết bài lab

B1. Truy cập trang chủ của website và cấu hình trình duyệt sử dụng Burp Suite làm proxy để theo dõi các yêu cầu HTTP và ấn vào tech gifts



B2.Xác định request chứa TrackingId

Trong Burp Suite, kiểm tra các request HTTP và xác định cookie:



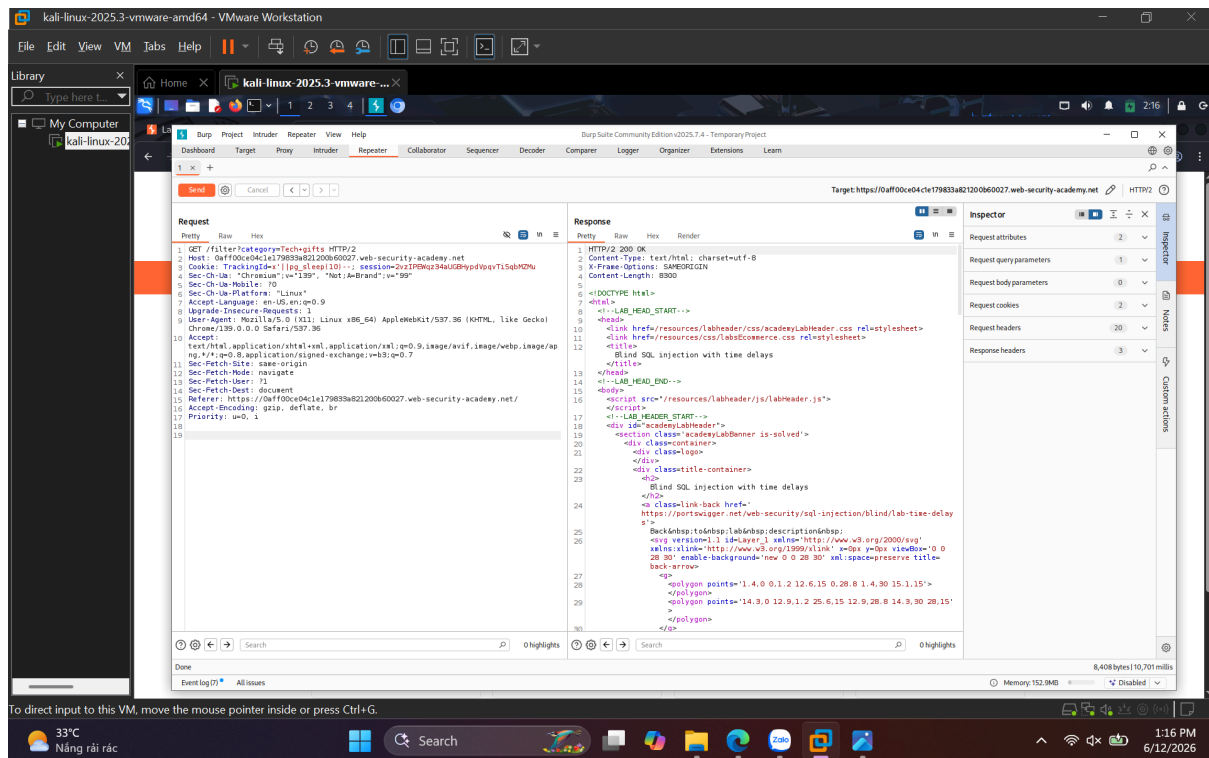
B3.Chỉnh sửa giá trị TrackingId

Chuyển request sang Repeater và thay đổi giá trị cookie thành:

TrackingId=x'||pg_sleep(10)--

Trong đó:

1. x' đóng chuỗi SQL ban đầu.
2. || là toán tử nối chuỗi của PostgreSQL.
3. pg_sleep(10) yêu cầu cơ sở dữ liệu tạm dừng xử lý trong 10 giây.
4. -- dùng để comment phần còn lại của câu lệnh SQL.



B4: Sau khi send request chứa payload SQL Injection, thời gian phản hồi của ứng dụng tăng lên khoảng 10 giây và có thể xem được thời gian ở dưới góc phải hình ảnh. Kết quả là thành công.

kali-linux-2025.3-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

kali-linux-2025.3

kali-linux-2025.3-vmware-amd64

1 2 3 4

Lab: Blind SQL Injection with time delays

https://0aff00ce04c1e179833a821200b60027.web-security-academy.net/filter?category=Tech+gifts

WebSecurity Academy

Blind SQL injection with time delays

LAB Solved

Back to lab description >

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account

WE LIKE TO SHOP

Tech gifts

Refine your search:

All Accessories Clothing, shoes and accessories Corporate gifts Gifts Tech gifts



To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

33°C Nắng rải rác

Search

1:16 PM 6/12/2026